PONTIFÍCIA UNIVERSIDADE CATÓLICA DE GOIÁS

COORDENAÇÃO ENSINO A DISTÂNCIA – CEAD

ESCOLA POLITÉCNICA E DE ARTES

ANÁLISE E DESENVOLVIMENTO DE SISTEMAS

Fórum Avaliativo

Segurança da Informação

Isaías Correia de Morais

Matrícula: 1132024100768

GOIÂNIA

2025.

PUC GOIÁS	**Disciplina:** Segurança da Informação **Docente:** Thalles Bruno Gonçalves Nery dos Santos **Discente:** Isaías Correia De Morais **Data:** 31/10/2025.

Análise de Risco de Segurança em Aplicações Web

A análise de riscos de segurança em aplicações web e um processo sistemático, em Tecnologia da Informação principalmente na Segurança da Informação que envolve a identificação, avaliação, correção de vulnerabilidades que se podem encontrar durante o desenvolvimento do projeto nas aplicações web, com o uso deste processo ajuda – se equipes as identificar falhas, erros que podem comprometer o sistema perdendo a consistência com os pilares da segurança da informação que são confidencialidade, integridade, disponibilidade e autenticidade.

A importância deste processo de analisar os riscos em aplicações web uma solução eficaz de encontrar vulnerabilidades no software evitando acessos não autorizados modificações ou uso indevido, encontrar erros o mais cedo possível antes que sejam exploradas por pessoas maliciosas, com essas análises de risco uma prevenção antecipara possíveis falhas futuras de segurança que podem ser corrigidas reparadas e testar se não vai ocorrer o mesmo problema.

Se não utilizar a análise de riscos de segurança de forma adequada desenvolvedores podem deixar brechas no sistema facilitando ataques como o roubo de dados, invasões, modificações não autorizadas e interrupção de serviços, fazendo com o oque a empresa ou órgãos perdam clientes, lucros financeiros, fiquem abaixo do que se previa e danos a reputação da empresa.

Metodologia STRIDE: Metodologia desenvolvida pela Microsoft modelo que auxilia na identificação de ameaças, propondo solução para o problema composto em seis categorias:

- **S – Spoofing (Falsificação):** Envolve acessar ilegalmente e, em seguida, usando as informações de autenticação de outro usuário, como o nome de usuário e senha.

- **T – Tampering (Adulteração):** Envolve a modificação mal-intencionada de dados. Os exemplos incluem alterações não autorizadas feitas em dados persistentes, como as mantidas em um banco de dados e a alteração de dados enquanto estão fluindo entre dois computadores em uma rede aberta, como a internet.

- **R – Repudiation (Repúdio):** Associado aos usuários que negam a execução de uma ação sem ter alguma maneira de provar o contrário – por exemplo, um usuário executa uma operação ilegal em um sistema que não tem capacidade para rastrear as operações proibidas. Não repúdio refere – se à capacidade de um sistema para combater ameaças de repúdio. Por exemplo, um usuário que adquire um item pode ter que inscrever o item após o recebimento. O vendedor pode usar o recibo assinado como prova de que o usuário recebeu o pacote.

- **I – Information Disclosure (Divulgação de Informações Confidenciais):** Envolve a exposição de informações para os indivíduos que não devem para ter acesso a ele – por exemplo, a capacidade dos usuários para ler um arquivo que não tem permissão de acesso para ou a capacidade de um intruso ler dados em trânsito entre dois computadores.

- **D – Denial of Service (Negação de Serviço):** Ataques negação de serviço (DoS) negar serviços a usuários válidos – por exemplo, fazendo um servidor Web temporiamente indisponível ou inutilizável. Você deve se proteger contra determinados tipos de ameaças DoS simplesmente para melhorar a confiabilidade e disponibilidade do sistema.

- **E – Elevation of Previlege (Elevação de Privilégio):** Um usuário sem privilégios obtém acesso privilegiado e, portanto, tem acesso suficiente para comprometer ou destruir todo o sistema. Elevação de ameaças de privilégios incluem situações em que um invasor penetra de forma eficaz todas as defesas do sistema e se tornam parte do sistema confiável em si, uma situação perigosa, de fato.

A metodologia **STRIDE** é utilizada na área de segurança da informação e tem como objetivo principal a identificação e classificação sistemática de ameaças e vulnerabilidades em sistemas aplicações e arquiteturas de software, uma abordagem de mitigar problemas e resolver com soluções com categorias propondo cada categoria uma solução diferente.

Metologia OWASP Top 10: Metodologia chamada (**Open Web Application Security Project**) uma organização sem fins lucrativos que tem como objetivo melhorar a segurança de softwares e aplicações web globalmente.

- **A01:2021 – Broken Acess Control (Controle de Acesso Quebrado):** Ocorre quando usuários conseguem acessar recursos ou funções que deveriam ser restritos.

- **A02:2021 – Cryptographic Failures (Falhas Criptográficas):** Envolve a exposição de dados sensíveis por uso incorreto ou ausência de criptografia adequada.

- **A03:2021 – Injection (Injeção):** Quando comandos maliciosos são inseridos em campos de entrada, como SQL Injection ou NoSQL Injection.

- **A04:2021 – Insecure Design (Design Inseguro):** Falhas estruturais no design da aplicação, que permitem comportamentos perigosos mesmo antes da codificação.

- **A05:2021 – Security Misconfiguration (Configuração de Segurança Incorreta):** Configurações padrão, permissões abertas ou serviços desnecessários que facilitam ataques.

- **A06:2021 – Vulnerable and Outdated Components (Componentes Vulneráveis e Desatualizados):** Uso de bibliotecas, frameworks ou plugins com falhas conhecidas.

- **A07:2021 – Identification and Authentication Failures (Falhas de Identficação e Autenticação):** Problemas em login, controle de sessão e gerenciamento de senhas.

- **A08:2021 – Software and Data Integrity Failures (Falhas de Integridade de Software e Dados):** Ausência de verificação da integridade de código e dados, oque permite inserção de componentes maliciosos.

- **A09:2021 – Security Logging and Monitoring Failures (Falhas de Registro e Monitoramento de Segurança):** Ausência de logs e monitoramento que dificultam a detecção de ataques e incidentes.

- **A10:2021 – Server-Side Request Forgery – SSRF (Falsificação de Requisição no Lado do Servidor):** Ocorre quando um atacante faz o servidor enviar requisições não autorizadas para outros sistemas.

Estas categorias apresentadas representam os tipos de falhas mais exploradas por atacantes e que mais comprometem a confidencialidade, integridade e disponibilidade das aplicações web.

Exemplo de Aplicações que teria Grandes Problemas de Segurança se a Análise de Riscos não fosse realizada.

Aplicação web de banco digital internet banking, que permite aos usuários criar contas, visualizar saldos, fazer transferências de pagamentos, receber, depósitos digitais a empresa que criou esse aplicativo lançou rapidamente o sistema sem fazer a validação de uma análise de risco detalhada, sem está análise várias vulnerabilidades passam despercebidas como:

- **Falhas de Autenticação:** O sistema não possui limitação de tentativas de login, permitindo ataques de força bruta sem que haja um bloqueio determinado para bloquear a aplicação imediatamente.

- **Ausência de Criptografia:** Dados sensíveis como senhas e números de cartão e informações pessoais são armazenados em texto simples no banco de dados, sem ter um embaralhamento usando tecnologias avançadas de criptografia.

- **Injeção SQL:** Campos de entrada como usuário e senha não são devidamente validados possibilitando que invasores executam comandos SQL para acessar ou apagar informações.

- **Falta de Logs e Monitoramento:** Quando um ataque ocorre não há registros suficientes para rastrear o invasor ou entender o impacto.

Conclusão

A análise de risco e essencial para empresas e pessoas para poderem identificar falhas erros graves problemas, que podem prejudicar mas no futuro, fazendo que protejam os usuários e as organizações descobrir falhas mas cedo garante mais segurança para as organizações quantos paras os clientes que estão desfruindo de aplicações web desde de aplicações simples como um streaming, até aplicações de bancos até de lojas virtuais e protegendo os dados pessoais desde de números de cartões a credenciais importantes aplicando as metodologias como STRIDE e o OWASP TOP 10 e possível desenvolver aplicações web mais seguras confiáveis, obedecendo os pilares da segurança da informação como confidencialidade, integridade e disponibilidade e desenvolver aplicações mais seguras confiáveis e acessíveis.